



Lab 4 — Build the Business Case for AI Security Governance

Topic 01: AI Security Governance Foundations and Business Risks

Objective: Analyse the cost of inaction and present a business case that justifies AI security governance investment to a board.

Goal: Governance competes for budget. You will quantify NovaBank's exposure using the incident pack and the cost assumptions provided, then produce a one-page board paper that argues for the governance programme in the language executives use: risk reduction, regulatory exposure and time to deploy.

What you'll build: A one-page board paper with a quantified exposure estimate, three prioritised investments and the expected risk reduction for each.

Tools and data: Incident cost pack (incident-cost-assumptions.csv, sector-incident-data.csv), board paper template

Data files in this lab

- data/board-paper-template.md
- data/incident-cost-assumptions.csv
- data/sector-incident-data.csv

Step-by-step

1. Open incident-cost-assumptions.csv and sector-incident-data.csv in labs/lab-04-business-case/data/ and identify the four cost categories: regulatory, remediation, business interruption and reputational.
2. Use your Lab 1 inventory to count NovaBank's High-risk AI systems and the number that process personal data.
3. Estimate annual expected loss for one realistic scenario — a prompt-injection data leak from a customer-facing agent — using the likelihood and impact figures in the cost pack.
4. Add the regulatory dimension: note the PDPA financial penalty exposure and the reputational consequence of a reported breach for a licensed financial institution.
5. Identify the three highest-value governance investments from your findings so far: the AI inventory and ownership, an acceptable-use policy with mandatory logging, and pre-deployment risk assessment with a human approval gate.
6. For each investment, estimate cost, time to implement and the specific risk it reduces. Express the reduction as a change in likelihood or impact, not as a vague improvement.

7. Add the enabler argument: governed organisations deploy faster because approval and evidence are routine. Quantify it as weeks saved per AI project.
8. Write the one-page board paper: the exposure, the three investments, the expected reduction, and a single clear ask.
9. Present your paper in two minutes to the class and take one challenge question from the trainer acting as CFO.

Test it

Your board paper fits on one page, states a number for annual expected loss with its assumptions visible, and each of the three investments names the specific risk it reduces. You can answer the CFO challenge 'why not just buy a tool?' in one sentence.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.